

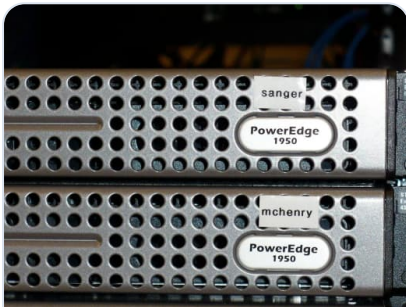
SÉCURITÉ DES APPLICATIONS WEB

Guide du TP 4 : sessions, jetons JWT et mots de passe

TP 4 · Sessions, jetons et mots de passe

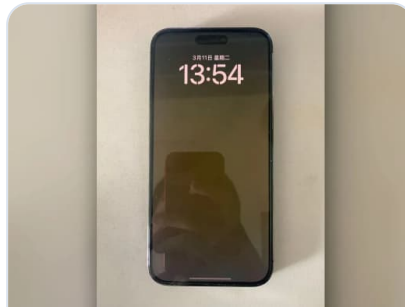


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



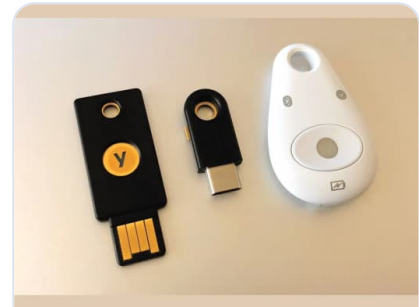
Serveur

Fournit fichiers, messagerie ou site web aux autres



Smartphone

Messages, photos, argent mobile et codes



Clé de sécurité matérielle (FIDO2)

Prouve ton identité, résiste à l'hameçonnage

Photos issues de Wikimedia Commons : Serveur, Florence Devouard, CC BY-SA 4.0 · Smartphone, 茅野ふたば, CC BY-SA 4.0 · Clé de sécurité matérielle (FIDO2), Tony Webster, CC BY 2.0.

CADRE ET LIMITES

- ◆ Toutes les données de ce laboratoire sont fictives et figées.
- ◆ Tu analyses uniquement des fichiers fournis ; ne teste jamais un système réel sans autorisation écrite.
- ◆ Les exemples ci-dessous utilisent des valeurs inventées, pas celles du labo.

Lire un JWT sans le confondre avec un secret

Un JWT signé en JWS contient trois parties séparées par des points : en-tête, charge utile, signature. Les deux premières parties sont simplement encodées en base64url. Elles sont lisibles ; elles ne chiffrent rien.



Calculer une signature HMAC sur un exemple inventé

BASH

```
cat > demo-jwt.txt <<'EOF'
X-
01;eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJkZW1vLXVzZXIiLCJhdWQiOiJkZW1vLWFWaSIImIhdCI6MTc2MjQxNjQwMCwiZXhwIjoxNzYyNDI5OTU5fQ.EOF
header=$(cut -d';' -f2 demo-jwt.txt | cut -d'.' -f1 | tr '_-' '/' | awk '{ pad=(4-length($0)%4)%4; printf "%s", $0;
for(i=0;i<pad;i++) printf "=" }' | base64 -d)
body=$(cut -d';' -f2 demo-jwt.txt | cut -d'.' -f1-2)
sig=$(printf '%s' "$body" | openssl dgst -sha256 -binary -hmac 'secret-guide-demo' | openssl base64 -A | tr '+/' '-_' | tr
-d '=')
printf 'D mo JWT pr te : %s partie(s), signature calcul e sur un exemple invent .\n' "$(printf '%s' "$body.$sig" | awk -
F'.' '{print NF}')"
printf 'En-t te d cod  : %s\n' "$header"
```

Commande longue, coup e par la mise en page : copie-la en une seule ligne ou utilise la version texte indiqu e en fin de document.

POWERSHELL

```
@'
X-
01;eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiJkZW1vLXVzZXIiLCJhdWQiOiJkZW1vLWFWaSIImIhdCI6MTc2MjQxNjQwMCwiZXhwIjoxNzYyNDI5OTU5fQ.EOF
'@ | Set-Content -Encoding UTF8 demo-jwt.txt
$jwt = (Get-Content -Encoding UTF8 demo-jwt.txt).Split(';')[1]
$parts = $jwt.Split('.')
$padding = $parts[0].Replace('-', '+').Replace('_', '/')
while (($padding.Length % 4) -ne 0) { $padding += '=' }
$header = [Text.Encoding]::UTF8.GetString([Convert]::FromBase64String($padding))
$body = "$($parts[0]). $($parts[1])"
$hmac = New-Object System.Security.Cryptography.HMACSHA256
$hmac.Key = [Text.Encoding]::UTF8.GetBytes('secret-guide-demo')
$sigBytes = $hmac.ComputeHash([Text.Encoding]::UTF8.GetBytes($body))
$sig = [Convert]::ToBase64String($sigBytes).TrimEnd('=').Replace('+','-').Replace('/','_')
"D mo JWT pr te : $($parts.Count) partie(s), signature calcul e sur un exemple invent ."
"En-t te d cod  : $header"
```

Commande longue, coup e par la mise en page : copie-la en une seule ligne ou utilise la version texte indiqu e en fin de document.



Lire un journal de sessions

Quand tu relis « sessions.log », trie les  v nements par identifiant de session puis regarde trois points : l'identifiant change-t-il   la connexion, y a-t-il encore des requ tes accept es apr s « logout », et un trou de plus de 15 minutes est-il pourtant accept  ?



Lire un stockage de mots de passe

Rep re d'abord les pr fixes et les param tres num riques. Un format qui para t moderne peut pourtant devenir non conforme si son co t ou son nombre d'it rations est trop faible.



Visionneuse du site

Filtre d'abord sur des mots g n riques comme « logout », « login », « alg », « aud », « exp » ou « pbkdf2 », puis relis la ligne enti re avant de conclure.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).